



SECURE CODING

APA ITU SECURE CODING

Praktik menulis kode dengan memperhatikan potensi ancaman keamanan sejak awal

Tujuannya untuk mencegah kerentanan umum seperti injeksi perintah, manipulasi data, kebocoran informasi, dan eskalasi hak akses

Secure coding dilaksanakan di fase construction



ASPEK SECURE CODING

Validasi input
Error handling
Update library
Enkripsi
Menejemen memory dan sesi
Code review

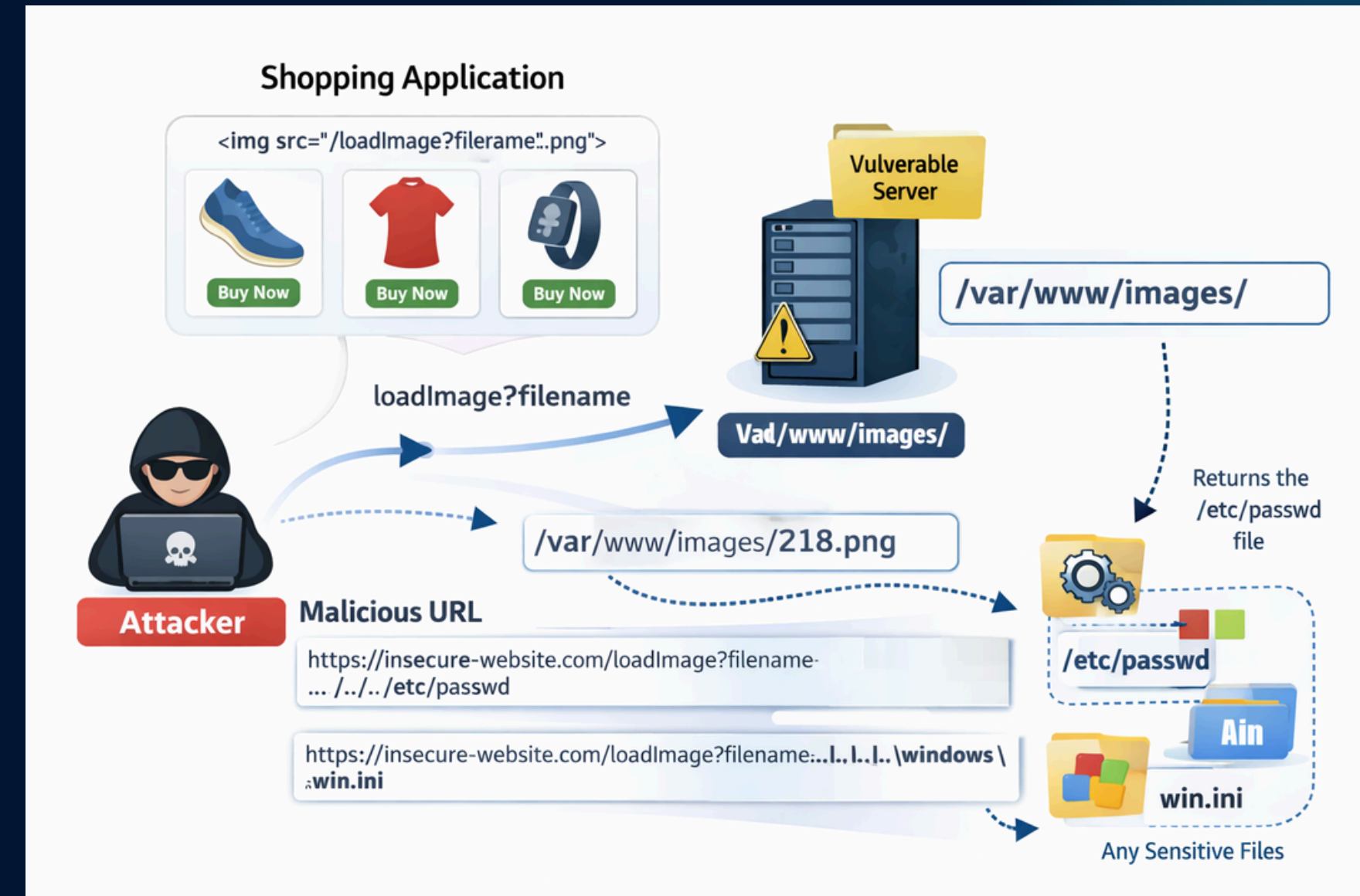


PATH TRAVERSAL

Kerentanan yang memungkinkan penyerang membaca berkas apa pun di server tempat aplikasi dijalankan

Kerentanan ini dapat digunakan untuk mengakses

- Kode dan data aplikasi.
- Kredensial untuk sistem backend.
- Berkas sistem operasi yang bersifat sensitif.



KASUS DI LARAVEL

```
Route::get('/download', function(IlluminateHttpRequest $request) {  
    return response()->download(storage_path('app/'.$request->get('filename')));  
});
```

Untuk bisa mendownload file, pengguna harus memasukkan nama file yang diinginkan, misal <https://example.com/download?filename=PrivateDocument.pdf>.

Fitur ini akan berjalan dengan baik jika input request yang diberikan menggunakan nama file yang valid.

Namun jika pengguna memasukkan nama file `../../.env`, maka penyerang akan mendownload file konfigurasi `.env` dari laravel yang berisi data data sensitif.

SOLUSI DI LARAVEL

```
Route::get('/download', function(IlluminateHttpRequest $request) {  
    $filename = basename($request->get('filename'));  
    return response()->download(storage_path('app/'.$filename));  
});
```

SOLUSI DI LARAVEL

```
Route::get('/download', function(IlluminateHttpRequest $request) {  
    $basepath = storage_path('app');  
    $filename = realpath($basepath.'/'.$request->get('filename'));  
    if ($filename !== false && substr($filename, 0, strlen($basepath)) ==  
    $basepath)  
        return response()->download($filename);  
  
    App::abort(404);  
});
```

MENCEGAH PATH TRAVERSAL DI LARAVEL

Validasi dan Sanitasi Input

Gunakan `basename()` pada input pengguna

misal: `basename($request->input('file'))`.

Terapkan whitelist hanya untuk jenis file yang diizinkan (misal: hanya .jpg, .pdf).

Hapus karakter khusus atau pola .. menggunakan regex seperti `preg_replace("/[^\a-zA-Z0-9.]/", "", $filename)`.

Gunakan Filesystem Storage Laravel

Jangan pernah menggunakan fungsi PHP mentah seperti `file_get_contents()` atau `include()` dengan input pengguna.

Gunakan facade Storage yang lebih aman.

Contoh aman: `Storage::disk('local')->download($safeFileName)`.

MENCEGAH PATH TRAVERSAL DI LARAVEL

Hindari getClientOriginalName():

Jangan pernah mempercayai getClientOriginalName() dari upload file.

Selalu buat nama file baru secara acak atau gunakan store() untuk menyimpan.

Batasi Izin File Server:

Pastikan web server (misal: Apache, Nginx) hanya memiliki hak akses baca/tulis ke direktori yang diperlukan, bukan seluruh direktori aplikasi, terutama file sensitif seperti .env.

Penyimpanan di Luar public/:

Simpan file yang diunggah di storage/app (direktori privat) dan akses melalui controller yang terautentikasi, jangan menyimpannya langsung di folder public/